

Manual 27 — Implementação Controlada de Governança de Dados e Engenharia de Privacidade

Tradução de projeto pt-BR — não oficial

****Ordem da série:** 27**

****Base publicada do NIST:** NIST Privacy Framework 1.0**

****Vigilância de mudanças:** versão preliminar pública inicial do NIST Privacy Framework 1.1 / versão final futura**

****Referência de engenharia de privacidade:** NISTIR 8062**

****Limite:** Este manual é orientação de implementação, não assessoria jurídica, aprovação regulatória, certificação nem substituto da legislação aplicável por jurisdição.**

01. Propósito, escopo e limites

Defina práticas empresariais de governança de dados e engenharia de privacidade sem confundir orientação com obrigações jurídicas específicas de uma jurisdição.

02. Hierarquia de fontes e controle de mudanças

Separe leis/regulamentos, orientação de reguladores, NIST Privacy Framework, orientação de engenharia de privacidade, contratos, políticas e padrões internos.

03. Modelo operacional de governança de dados

Defina conselhos, stewards, custodians, proprietários, privacidade, segurança, jurídico, registros, arquitetura e papéis de responsabilidade do negócio.

04. Inventário e linhagem de dados

Mantenha inventários autoritativos de domínios de dados, sistemas, fluxos, armazenamentos, operadores/processadores, transferências e relações de linhagem.

05. Classificação e tratamento

Estabeleça critérios de classificação, regras de tratamento, condições de acesso, limites de compartilhamento, requisitos de proteção e evidências.

06. Especificação de finalidade e limitação de uso

Registre finalidades de negócio aprovadas, usos compatíveis, restrições, responsáveis, gatilhos de revisão e exceções.

07. Minimização de dados

Colete, crie, retenha e exponha somente dados proporcionais às finalidades e obrigações definidas.

08. Qualidade e exatidão dos dados

Defina dimensões de qualidade, validação, correção, propriedade, monitoramento e controles de gestão de problemas.

09. Retenção e exclusão

Implemente cronogramas de retenção, legal holds, exclusão, arquivamento, descarte, exceções e evidência de execução.

10. Governança de acesso

Aplique menor privilégio, controles baseados em papéis/atributos, acesso privilegiado, revisão periódica, segregação e revogação.

11. Compartilhamento e divulgação de dados

Controle o compartilhamento interno e externo por meio de autorização, acordos, restrições de finalidade, minimização, registro e revisão.

12. Fluxos transfronteiriços e jurisdicionais de dados

Mantenha avaliações jurídicas/contratuais de transferência e evite presumir que um único mecanismo global se aplica em todos os lugares.

13. Avaliação de riscos de privacidade

Identifique danos à privacidade, pessoas afetadas, probabilidade, severidade, mitigações, risco residual e gatilhos de reavaliação.

14. Objetivos de engenharia de privacidade

Traduza objetivos de privacidade em propriedades de sistema como previsibilidade, gerenciabilidade, dissociabilidade, controle e transparência.

15. Privacidade desde a concepção e por padrão

Incorpore requisitos de privacidade à arquitetura, SDLC, aquisições, gestão de mudanças e configurações padrão.

16. Gestão de consentimento e preferências

Quando aplicável, governe avisos, escolhas, estado de consentimento, retirada, propagação de preferências, evidências e exceções.

17. Operações de direitos individuais

Suporte acesso, correção, exclusão, portabilidade, oposição, restrição e outros direitos aplicáveis com fluxos de trabalho conscientes da jurisdição.

18. Proteção de identidade e dados sensíveis

Aplique governança reforçada a identificadores, credenciais, dados de saúde, financeiros, biométricos, localização precisa, dados de crianças e dados semelhantes quando aplicável.

19. Desidentificação e pseudonimização

Defina técnicas aprovadas, avaliação de risco de reidentificação, controles, testes, contratos e restrições de uso.

20. Tecnologias de aprimoramento da privacidade

Avalie criptografia, tokenização, computação segura, privacidade diferencial, técnicas federadas, dados sintéticos e outras PETs de forma proporcional ao risco.

21. Registro, monitoramento e observabilidade

Registre acessos, compartilhamento, exclusão, estado de consentimento, solicitações de direitos, exceções de política e mudanças materiais nos fluxos de dados.

22. Governança de dados de terceiros

Avalie operadores/fornecedores, instruções, subprocessamento, evidências, controles de segurança/privacidade, retenção, exclusão e obrigações de incidentes.

23. Governança de nuvem e plataformas de dados

Governe data lakes, warehouses, SaaS, plataformas analíticas, object stores, APIs, notebooks e compartilhamento entre contas.

24. Análise e uso secundário

Revise novas análises, enriquecimento, inferências, profiling e reutilização quanto à compatibilidade de finalidade, risco de privacidade, equidade e transparência.

25. Arquitetura de registros e evidências

Mantenha decisões, avaliações, aprovações, mapeamentos, exceções, avisos, contratos, logs, registros de problemas e evidências de remediação.

26. Coordenação de incidentes e violações

Integre a governança de dados à detecção, contenção, avaliação, notificação, recuperação e lições aprendidas de incidentes de segurança/privacidade.

27. Métricas e indicadores

Acompanhe cobertura de inventário, qualidade de dados, desempenho de direitos, execução de retenção, revisão de acesso, risco de privacidade, problemas de fornecedores e envelhecimento de remediação.

28. Treinamento e competência por função

Forneça treinamento baseado em função para proprietários, stewards, engenheiros, analistas, privacidade, segurança, aquisições e liderança.

29. Assurance e testes

Teste o desenho e a operação da governança por amostragem, validação de controles, testes técnicos, revisão de solicitações de direitos e inspeção de evidências.

30. Análise crítica pela gestão

Revise desempenho, mudança regulatória, incidentes, risco de privacidade, métricas, exceções, recursos e prioridades de melhoria.

31. Melhoria contínua

Use achados, incidentes, reclamações, resultados de auditoria, mudanças tecnológicas e regulatórias para impulsionar melhorias controladas.

32. Publicação e roteiro de implementação

Empacote caminhos de implementação Essencial / Estruturado / Aprimorado com verificação de fontes, localização, acessibilidade, proveniência, checksums, segurança de workflows, evidência de revisão humana quando exigida e controles de publicação sequencial.